UNIVERSIDAD DEL VALLE
FACULTAD DE INGENIERÍA — ESCUELA DE SISTEMAS
MAESTRÍA EN DESARROLLO DE APLICACIONES INTELIGENTES
SEGURIDAD EN EL DESARROLLO DE APLICACIONES

Punto 2. Análisis de factibilidad con MITRE ATLAS

Módulo Tres: tareas de equipo púrpura para sistemas basados en IA

Miguel Ángel Rincón — 2502619-7729
Maria Paula Jimenez I — 2507713-7729
David Steven Duran Vallejo — 2508228-7729

Resultado. Se seleccionan tres técnicas de MITRE ATLAS con madurez *Realized* y plataforma *Predictive AI*: modificación manual de entradas, envenenamiento de datos de entrenamiento y extracción del modelo. La selección se realizó sobre los componentes que existen en el prototipo ejecutable de FinanCali y no sobre amenazas genéricas de inteligencia artificial.

2.1. Método y fuente de evaluación

El análisis utiliza la distribución oficial MITRE ATLAS 2026.09 [1]. En esa versión, la madurez expresa el nivel de evidencia de uso de una técnica: *Feasible* corresponde a investigación o viabilidad técnica; *Demonstrated*, a una prueba o ejercicio sobre un sistema realista; y *Realized*, al uso observado por un actor de amenaza en un incidente real [1]. El Módulo Tres exige seleccionar entre dos y tres técnicas de madurez realizada; por ello, la madurez se utilizó como filtro y no como puntuación subjetiva.

Para comparar las técnicas que superaron ese filtro se definieron cinco criterios antes de puntuarlas. Cada criterio se valora de 1 a 5 y se pondera sobre 100 puntos:

Tabla 1. Criterios de priorización

Criterio	Pregunta de evaluación	Peso
Alineación técnica	¿Existe en FinanCali el componente que la técnica necesita?	25 %
Facilidad de acceso	¿Qué privilegio o posición necesita el adversario?	20 %
Impacto	¿Puede alterar decisiones, confidencialidad o continuidad?	20 %
Reproducibilidad segura	¿Puede probarse localmente con datos sintéticos y sin afectar terceros?	20 %
Observabilidad defensiva	¿La prueba permite producir evidencia de Identificar, Proteger y Detectar?	15 %

Superficie efectivamente disponible

El prototipo posee un dataset sintético determinista de 4.000 registros, un pipeline de entrenamiento por lotes, un `GradientBoostingClassifier`, una API `POST /api/score`, una interfaz web y métricas de línea base. La API valida rangos, pero acepta desde el cliente todas las variables, incluidas las que en un sistema real deberían provenir de fuentes confiables, como el indicador externo y las moras. Además, devuelve score, probabilidad y versión del modelo; no implementa autenticación, cuota de consultas ni limitación de tasa porque todavía es un laboratorio local.

```
ENTRENAMIENTO
Generador sintético → preparación → GradientBoostingClassifier
→ métricas → artefacto lógico y hashes

INFERENCIA
Formulario / cliente → POST /api/score → validación de rangos
→ probabilidad → score → aprobar / revisar / rechazar

PUNTOS DE ACCESO
Entrada pública simulada | repositorio/pipeline interno | API de inferencia
```

2.2. Técnica 1 — Modificación manual de entradas

AML.T0043.003 · Realized MITRE ATLAS describe esta técnica como la modificación manual de los datos de entrada usando conocimiento del modelo y prueba y error hasta conseguir una entrada adversarial funcional [1]. Está incluida en la táctica de preparación de datos adversariales y aplica a modelos predictivos.

Tabla 2. Factibilidad de AML.T0043.003

Aspecto	Análisis para FinanCali
Componente afectado	Formulario de solicitud, contrato `ScoreRequest`, endpoint `/api/score` y umbrales de decisión.
Acceso requerido	Acceso ordinario al canal de solicitud o capacidad para enviar solicitudes HTTP. No requiere acceso al código, al modelo ni al dataset.
Exposición actual	Alta en el prototipo: todas las variables viajan en el cuerpo de la petición. En el caso conceptual sería media: la API es interna, pero recibe datos originados en la aplicación y en integraciones.
Ruta de ataque	Partir de una solicitud cercana al umbral y alterar iterativamente variables hasta pasar de rechazo o revisión a aprobación. Un caso crítico consiste en enviar como si fueran declaradas variables que deberían obtenerse del buró, por ejemplo `external_risk_score` o `late_payments_12m`.
Impacto	Aprobación incorrecta, pérdida financiera, elusión de la revisión humana y degradación de la confianza en el scoring.
Factibilidad	**Alta.** El componente existe, la superficie es directamente accesible y la prueba puede realizarse con solicitudes sintéticas sin modificar el modelo.
Evidencia posible	Payload inicial y alterado, número de intentos, cambio del score, cruce de umbral, logs y respuesta del control defensivo.

La defensa no debe limitarse a validar rangos. Las variables se deben clasificar por procedencia: declaradas por el solicitante, derivadas por FinanCali y obtenidas de fuentes confiables. El cliente no debería poder enviar directamente las dos últimas. También se requieren validaciones cruzadas, límites de consultas, detección de patrones iterativos y envío a revisión cuando haya inconsistencias.

2.3. Técnica 2 — Envenenamiento de datos de entrenamiento

AML.T0020 · Realized ATLAS define el envenenamiento como agregar, eliminar o modificar muestras, etiquetas, anotaciones o procesos de recolección para influir en el comportamiento del modelo entrenado. El efecto puede persistir aun cuando el dato alterado ya no esté disponible [1].

Tabla 3. Factibilidad de AML.T0020

Aspecto	Análisis para FinanCali
Componente afectado	Generación o carga del dataset, etiquetas de resultado, preparación, pipeline de entrenamiento y nueva versión del modelo.
Acceso requerido	Escritura sobre el dataset o pipeline, credenciales privilegiadas, compromiso del repositorio/CI o control de una fuente externa incorporada al entrenamiento.

Aspecto	Análisis para FinanCali
Exposición actual	Baja para un atacante externo porque no existe endpoint de reentrenamiento. Media frente a un actor interno o una cuenta técnica comprometida. El Taller 1 ya identificó debilidades en accesos privilegiados al conjunto histórico.
Ruta de ataque	Cambiar un porcentaje de etiquetas, insertar registros dirigidos a un perfil o modificar la función generadora antes del entrenamiento. Después se publica una versión aparentemente válida.
Impacto	Errores persistentes, sesgo dirigido, aprobación de perfiles concretos, degradación global y dificultad para localizar la causa después del despliegue.
Factibilidad	**Media.** El pipeline existe y la prueba es sencilla, pero el adversario necesita privilegios superiores a los de un solicitante.
Evidencia posible	Hash limpio y alterado, porcentaje envenenado, diferencias de ROC AUC/F1/Brier, tasa de aprobación por segmento y resultado del bloqueo del pipeline.

Los controles pertinentes son inventario y procedencia del dataset, permisos de escritura mínimos, hashes o versiones autorizadas, revisión de cambios, separación de funciones, validación de etiquetas y comparación automática contra una línea base antes de desplegar.

2.4. Técnica 3 — Extracción del modelo mediante la API

AML.T0024.002 · Realized ATLAS establece que un adversario puede consultar repetidamente una API de inferencia, usar las respuestas como etiquetas y entrenar fuera de línea un modelo sustituto que imite al original [1].

Tabla 4. Factibilidad de AML.T0024.002

Aspecto	Análisis para FinanCali
Componente afectado	Endpoint `/api/score`, salida probabilística, versión del modelo y ausencia de límites de consultas.
Acceso requerido	Acceso de caja negra a la API. No requiere pesos, código ni dataset original.
Exposición actual	Alta en el laboratorio local: no hay autenticación ni límite y se devuelve la probabilidad. Media en el caso conceptual porque la API es interna, pero una integración, credencial o servicio comprometido puede consultarla.
Ruta de ataque	Generar solicitudes sintéticas, registrar score/probabilidad, entrenar un modelo sustituto con esas respuestas y medir su acuerdo con FinanCali sobre un conjunto no utilizado en el copiado.
Impacto	Pérdida de propiedad intelectual y creación de un proxy para ensayar evasiones sin producir actividad visible sobre el sistema objetivo.
Factibilidad	**Media-alta.** Es reproducible y observable, pero necesita un volumen de consultas y su impacto inmediato sobre decisiones es menor que el de la modificación de entradas.
Evidencia posible	Número de consultas, distribución de entradas, acuerdo entre modelo original y proxy, aproximación del score y alertas por patrón automatizado.

Las defensas incluyen autenticación por servicio, autorización de mínimo privilegio, cuotas, rate limiting, monitoreo de consultas similares o sistemáticas, reducción de precisión de la salida cuando sea compatible con el negocio y protección de metadatos que no necesita el cliente.

2.5. Comparación y priorización

Tabla 5. Matriz ponderada de factibilidad (escala relativa, no probabilidad estadística)

Técnica	Madurez	Alineación 25 %	Acceso 20 %	Impacto 20 %	Prueba 20 %	Defensa 15 %	Total
AML.T0043.003 Modificación manual	Realized	5	5	4	5	5	**96/100**

Técnica	Madurez	Alineación 25 %	Acceso 20 %	Impacto 20 %	Prueba 20 %	Defensa 15 %	Total
AML.T0020 Envenenamiento	Realized	5	2	5	5	5	**88/100**
AML.T0024.002 Extracción del modelo	Realized	5	4	3	4	4	**81/100**

Selección propuesta. Las tres técnicas avanzan como amenazas pertinentes del Punto 2. Para la evaluación práctica del Punto 3 se prioriza **AML.T0043.003 — Manual Modification**, porque exige el menor privilegio, actúa sobre la superficie más expuesta y permite comparar de forma segura una solicitud base con intentos de manipulación. AML.T0020 queda como segunda opción por su mayor impacto persistente, y AML.T0024.002 como escenario complementario de confidencialidad y preparación de ataques.

Escenario recomendado para el Punto 3

1. Construir solicitudes sintéticas cercanas a los umbrales de 40 y 70.
2. Separar variables declarables de variables confiables o derivadas.
3. Modificar de forma iterativa una variable por intento y registrar cada respuesta.
4. Comprobar si se cruza un umbral modificando campos que el cliente no debería controlar.
5. Aplicar el control defensivo: retirar esos campos del contrato público, resolverlos en servidor, validar coherencia y registrar intentos.
6. Repetir las pruebas y aprobar si ninguna manipulación de campos no confiables produce una decisión automática.

Un posible criterio de aprobación es: “El sistema no acepta desde el cliente variables clasificadas como externas o derivadas; toda discrepancia produce rechazo de la solicitud o revisión manual y genera un evento auditable”. Las entradas, respuestas, logs y comparación antes/después constituirán la evidencia del ejercicio púrpura.

2.6. Técnicas consideradas y no priorizadas

Técnica	Razón para no priorizarla
AML.T0024.000 Infer Training Data Membership	Su madurez en ATLAS 2026.09 es *Feasible*, no *Realized*. Además, el prototipo solo contiene datos sintéticos y no existe afectación de privacidad a titulares reales.
AML.T0024.001 Invert AI Model	Madurez *Feasible* y baja pertinencia inmediata por la ausencia de información personal real en el entrenamiento.
AML.T0043.001 Black-Box Optimization	Madurez *Demonstrated*. Es técnicamente posible con ART, pero no satisface por sí sola el filtro principal del módulo.
Prompt injection y ataques a RAG	No aplican: FinanCali usa un clasificador tabular, no un modelo de lenguaje, RAG, prompts o agentes.
Denial of AI Service	Es una amenaza válida, pero el modelo es pequeño y su costo computacional es bajo. Aporta menos al análisis específico de seguridad del modelo que las tres técnicas seleccionadas.

2.7. Conclusión

La arquitectura implementada permite justificar tres técnicas realizadas de ATLAS sin inventar componentes. La modificación manual explota el límite de confianza entre el cliente y la API; el envenenamiento compromete la integridad del aprendizaje; y la extracción aprovecha la observación repetida de las salidas. Las tres cubren superficies diferentes y producen evidencia compatible con las funciones Identificar, Proteger y Detectar de NIST CSF 2.0.

La modificación manual se recomienda para la prueba práctica porque es la amenaza más accesible y directamente observable en el prototipo actual. Esta decisión no significa que sea el riesgo de mayor impacto absoluto: el envenenamiento podría ser más grave, pero requiere acceso privilegiado. La priorización expresa, por tanto, factibilidad para el

ejercicio académico y no una estimación financiera de riesgo residual.

Referencias

1. MITRE ATLAS. *ATLAS Data 2026.09*. Técnicas AML.T0043.003, AML.T0020 y AML.T0024.002. https://github.com/mitre-atlas/atlas-data/blob/main/dist/v6/ATLAS-2026.09.yaml
2. Universidad del Valle. *Módulo Tres: Tareas de equipo púrpura para sistemas basados en IA*. Seguridad en el Desarrollo de Aplicaciones, 2026-II.
3. FinanCali S.A.S. *Punto 1 — Definición del caso de uso de IA*. Artefacto académico del Módulo Tres.
4. National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29, 2024.